



RISE & SHINE ABA LLC

Empowering children to reach their full potential

HIPAA & CONFIDENTIALITY AGREEMENT

Document v2.0 · Effective May 2026

1. Purpose

This Agreement defines the legal, professional, and ethical responsibilities of every Rise & Shine ABA employee and contractor regarding the protection of Protected Health Information (PHI), Electronic Protected Health Information (ePHI), and other Confidential Information. Rise & Shine ABA is a Covered Entity under the federal Health Insurance Portability and Accountability Act (HIPAA), the HITECH Act, and applicable New York State privacy laws.

2. Definitions

Protected Health Information (PHI)

Any individually identifiable health information transmitted or maintained in any form, including but not limited to:

- Client name, address, phone, email, date of birth, Social Security number
- Diagnosis (including autism spectrum disorder), assessment results, behavior plans, treatment plans, progress notes, session notes, behavioral data
- Insurance information, member ID, authorization numbers, claim information
- Photos, video, audio recordings of clients
- Any of the 18 HIPAA identifiers when linked to health information
- Verbal disclosures of any of the above

Electronic PHI (ePHI)

Any PHI created, stored, transmitted, or accessed electronically — including email, EHR systems, scheduling platforms, telehealth video, mobile devices, cloud storage, and messaging applications.

Confidential Information

Includes all PHI/ePHI plus internal company information: financials, employee records, business strategies, training materials, proprietary forms, and intellectual property.

3. Your Responsibilities

Access & Use

- Access PHI/ePHI only when required for your specific job duties.
- Use the minimum necessary information to complete each task — this is the federal "Minimum Necessary Rule."
- Never access records of clients you are not assigned to, even out of curiosity.

Confidentiality

- Do not disclose PHI to anyone not authorized to receive it — including spouses, friends, other RBTs not on the case, or anyone outside Rise & Shine ABA.
- Do not discuss client information in public spaces — coffee shops, public transit, elevators, hallways, social gatherings.
- Do not post about clients on social media in any form, even with names removed.
"De-identified" stories that include enough detail to identify a child remain HIPAA violations.

Security Measures

- Use only company-approved, password-protected, encrypted devices to access ePHI.
- Never store PHI on personal devices, personal email accounts, or personal cloud services (personal Google Drive, iCloud, Dropbox).
- Position screens so unauthorized persons cannot view client information.
- Log out of all systems when stepping away from your device.
- Never share login credentials with anyone — including coworkers, family, or supervisors.
- Use only Rise & Shine ABA-approved communication tools (HIPAA-compliant email, secure messaging, BAA-covered telehealth platforms) when transmitting PHI.
- Never transmit PHI by personal text message, personal email, or non-encrypted channels.

Telehealth & Remote Work

- Conduct sessions and access PHI only in a private, soundproof workspace where unauthorized persons cannot overhear or view your screen.
- Use a wired or password-protected encrypted Wi-Fi network. Never conduct telehealth sessions on public Wi-Fi without an approved VPN.
- Never record sessions without explicit written authorization from the client's parent/guardian and clinical supervisor.
- Maintain camera-ready professional appearance and conduct yourself as if in person.

Reporting

You must immediately report any of the following to the Compliance Officer or Director of Operations:

- Suspected or confirmed unauthorized disclosure of PHI
- Loss or theft of any device containing or able to access PHI
- Phishing, malware, or any suspected cyber-incident

- Mistaken transmission of PHI to wrong recipient
- Any conduct by another employee that may violate this Agreement

New York State requires that affected individuals be notified of a data breach without unreasonable delay, generally within 60 days of discovery. Your prompt internal report is what makes timely external notification possible.

4. Strictly Prohibited Conduct

- Taking screenshots, photos, or screen recordings of client records, screens, or PHI
- Storing PHI on personal devices, personal email, or personal cloud accounts
- Sending PHI by personal text message, personal email, or social media
- Sharing system login credentials with any person, including coworkers
- Removing client charts, documents, or any physical PHI from approved work environments without written authorization
- Discussing client information with media, journalists, or any third party without written authorization
- Using PHI for personal benefit, marketing, research, or any non-treatment purpose

5. Training Requirement

You will complete HIPAA Privacy and Security training before any access to PHI is granted, and you will repeat training annually thereafter. Completion certificates will be maintained in your personnel file. Failure to complete required training within deadlines may result in suspension of system access and disciplinary action.

6. Term & Survival

- This Agreement remains in force for the entire duration of your employment or contract with Rise & Shine ABA.
- Your obligations to protect PHI and Confidential Information continue **indefinitely after employment or contract termination.**
- Upon separation, you will return or securely destroy all PHI and Confidential Information in your possession, and you will sign a separation certification confirming this.

7. Consequences of Violation

Violations of this Agreement may result in:

- Disciplinary action, up to and including immediate termination
- **Federal civil penalties** under HIPAA: \$137 to \$68,928 per violation, with annual caps of up to \$2,067,813 (2024 figures, adjusted annually)

- **Federal criminal penalties** for knowing or willful violations: fines up to \$250,000 and up to 10 years imprisonment
- Personal civil liability if PHI is sold or used for personal gain
- Reporting to applicable licensing bodies (BACB, state professional boards)

8. No Retaliation

Rise & Shine ABA prohibits retaliation against any employee or contractor who in good faith reports a suspected HIPAA violation, refuses to participate in a violation, or cooperates in an investigation.

Concerns may be raised to the Compliance Officer, Director of Operations, or anonymously through the channels listed in the Employee Handbook.

9. Acknowledgment

By signing below, I certify that:

- I have read and understood this HIPAA & Confidentiality Agreement.
- I have completed (or will complete within my onboarding window) HIPAA Privacy and Security training.
- I understand my legal obligations under HIPAA, HITECH, and New York State privacy laws.
- I agree to comply fully with all Rise & Shine ABA privacy and security policies.
- I understand that violations may result in disciplinary action, including termination, and may carry personal legal and financial liability.

Employee/Contractor Full Name (Print)

Date

Position / Title

Signature

Office Use Only

Compliance Officer or Authorized Reviewer (Name & Signature)

Date

HIPAA Training Completed On

Filed In Personnel Record By
